MITRE ATLAS | AML.CS0032 - Attempted Evasion of ML Phishing Webpage Detection System

Entry Information

ID:
AML.CS0032

Type:
Case-Study

Name:
Attempted Evasion of ML Phishing Webpage Detection System

URL:
https://atlas.mitre.org/studies/AML.CS0032/

Incident Date:
2022-12-01

Target:
Commercial ML Phishing Webpage Detector

Actor:
Unknown

Description

Adversaries create phishing websites that appear visually similar to legitimate sites. These sites are designed to trick users into entering their credentials, which are then sent to the bad actor. To combat this behavior, security companies utilize AI/ML-based approaches to detect phishing sites and block them in their endpoint security products.

In this incident, adversarial examples were identified in the logs of a commercial machine learning phishing website detection system. The detection system makes an automated block/allow determination from the "phishing score" of an ensemble of image classifiers each responsible for different phishing indicators (visual similarity, input form detection, etc.). The adversarial examples appeared to employ several simple yet effective strategies for manually modifying brand logos in an attempt to evade image classification models. The phishing websites which employed logo modification methods successfully evaded the model responsible detecting brand impersonation via visual similarity. However, the other components of the system successfully flagged the phishing websites.

Attack Procedure:
[AML.T0043.003] Manual Modification: Several cheap, yet effective strategies for manually modifying logos were observed:

Evasive Strategy	Count
Company name style	25
Blurry logo	23
Cropping	20
No company name	16
No visual logo	13
Different visual logo	12
Logo stretching	11
Multiple forms - images	10

Background patterns	8
Login obfuscation	6
Masking	3

[AML.T0015] Evade AI Model: The visual similarity model used to detect brand impersonation was evaded. However, other components of the phishing detection system successfully identified the phishing websites.

[AML.T0052] Phishing: If the adversary can successfully evade detection, they can continue to operate their phishing websites and steal the victim's credentials.

[AML.T0048.003] User Harm: The end user may experience a variety of harms including financial and privacy harms depending on the credentials stolen by the adversary.

References

- "Real Attackers Don't Compute Gradients": Bridging the Gap Between Adversarial ML Research and Practice — https://arxiv.org/abs/2212.14315

- Real Attackers Don't Compute Gradients Supplementary Resources — https://real-gradients.github.io/